Table of Contents

Cisco Secure Workload — CIS Critical Security Controls v8.1

Reference Design | Implementation Group 2 Lead, with IG1 / IG3 Deltas

Version: 1.0 (draft — pending SME review) | **Standard:** CIS Critical Security Controls v8.1 | **Audience:** Security teams adopting or maintaining CIS Controls posture, particularly those targeting Implementation Group 2 (IG2) | **Environment:** Hybrid (on-prem + cloud + containers)

Reader's Guide

Who this is for. Organisations using the CIS Critical Security Controls (currently v8.1) as their primary cyber programme reference, or as an objective scorecard alongside another framework (HIPAA, SOC 2, PCI, NIST CSF, NIST 800-53). The default depth in this reference design is written for **Implementation Group 2 (IG2)** because that's the band most enterprise programmes operate in. IG1 and IG3 deltas are called out where the work materially changes.

Why CIS Controls and not just NIST 800-53? The CIS Controls are an **operationally ordered, prioritised** subset of what the broader NIST catalogue describes. Where 800-53 lists 1,000+ controls covering every conceivable scenario, CIS Controls compress the universe to 18 Controls and ~153 Safeguards, rank-ordered by what defends against actual attacks first. Many programmes use CIS as the "what to do this year" view and 800-53 as the "what to satisfy in the contract" view.

Questions this reference design helps you answer:

- *Control 1 (Inventory of Enterprise Assets) and Control 2 (Inventory of Software Assets): can I produce a current inventory of CSW-covered workloads and the software running on them, refreshed continuously and reconciled with the enterprise source of truth?*
- *Control 4 (Secure Configuration): can I detect drift from baseline configuration on CSW-covered workloads, attribute the change to a request ticket, and produce evidence per quarter?*
- *Control 7 (Continuous Vulnerability Management): for every CVE that drops, can I show which workloads are exposed, how reachable they are from current attacker positions, and how that backlog has trended?*
- *Control 8 (Audit Log Management): am I retaining audit-quality logs at the workload level for the period the Safeguards specify, with process attribution that supports incident reconstruction?*

- *Control 12 (Network Infrastructure Management) and Control 13 (Network Monitoring and Defense): can I prove segmentation between trust zones is enforced at the workload, not just configured at the edge, and that east-west traffic between workloads is observed and alertable?*
- *Control 17 (Incident Response Management): when an event is declared, can I assemble a forensic dossier (workloads, processes, flows, packages, baselines) within minutes rather than days?*

What you'll need. Your current self-assessed CIS Implementation Group rating (IG1 / IG2 / IG3), your existing inventory source of truth (CMDB, cloud-asset inventory, or both), your patch and change management ticketing system, and the SIEM destination for log forwarding. CSW augments these; it does not replace them.

Where to start. Section 2 if you're scoping CSW relative to your IG; sections 3–4 for the scope tree and the deny-by-default policy set everything else builds on; sections 5–7 if Controls 1, 2 and 4 are the priority gap; sections 8 and 11 if Controls 7 and 13 are the audit gap; section 9 if Control 8 logging retention is the open item; section 12 for the incident-response evidence pack (Control 17).

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	**Live** network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement **operates**

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: Compliance evidence playbook (full step-by-step) · About CSW (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope

- ☐ ADM-imported rules refined; Simulation run ≥1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- Direct evidence on Controls 1, 2, 4, 7, 8, 13
- IG2 lead with IG1/IG3 deltas documented in reference design
- Asset/software inventory + secure config from agent telemetry

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

---

1. Overview

CIS Critical Security Controls v8.1 organises 18 Controls and ~153 Safeguards by Implementation Group:

IG	Typical org profile	Safeguards
IG1	Small org, basic staff, limited resources, commodity hardware	56 Safeguards
IG2	Mid-to-large org, dedicated security function, mixed sensitivity	130 Safeguards (cumulative with IG1)
IG3	Large org, mature security, sensitive data,	153 Safeguards (cumulative with IG2)

IG	Typical org profile	Safeguards
	advanced threats	

A given Safeguard ID (e.g. `1.1`) is the same across IGs; what changes is whether it's in scope and the rigour expected. This reference design leads with IG2 expectations and notes IG1/IG3 deltas where the work materially changes.

Where CSW fits across the 18 Controls:

Control	Title	CSW relevance
1	Inventory and Control of Enterprise Assets	**Direct** — workload inventory, hardware/cloud asset attribution
2	Inventory and Control of Software Assets	**Direct** — installed software inventory per workload
3	Data Protection	Supporting (egress observation; primary control is DLP)
4	Secure Configuration of Enterprise Assets and Software	**Direct** — baseline + drift
5	Account Management	Out of scope (identity/PAM tooling)
6	Access Control Management	Supporting (workload-side enforcement; identity is upstream)
7	Continuous Vulnerability Management	**Direct** — continuous CVE inventory + reachability context
8	Audit Log Management	**Direct** — workload-level flow + process telemetry to SIEM
9	Email and Web Browser Protections	Out of scope (email/web stack)
10	Malware Defenses	Supporting (behavioural rules layer with endpoint AV)
11	Data Recovery	Out of scope (backup product)
12	Network Infrastructure Management	Supporting (workload-side; perimeter is upstream)

Control	Title	CSW relevance
13	Network Monitoring and Defense	**Direct** — east-west visibility, anomaly detection, deny-by-default
14	Security Awareness and Skills Training	Out of scope (HR/training)
15	Service Provider Management	Supporting (technical egress lens; contractual is upstream)
16	Application Software Security	Supporting (CVE inventory feeds the SDLC)
17	Incident Response Management	**Direct (evidence)** — forensic reconstruction bundle
18	Penetration Testing	Supporting (reachability validation; pre/post test reports)

CSW directly addresses six Controls (1, 2, 4, 7, 8, 13), supports six more (3, 6, 10, 12, 15, 16, 17 evidence side, 18), and is explicitly out of scope on five (5, 9, 11, 14, plus AT/MP/PE/PS-style items inside other controls).

---

2. Implementation Group Calibration

Before deploying, calibrate CSW scope to your IG target. The same sensors get installed; what differs is the breadth of the policy workspace and the cadence of evidence pulls.

Aspect	IG1 baseline	IG2 baseline (default)	IG3 add
Sensor coverage	All servers + admin workstations	All workloads incl. containers + cloud workloads	All workloads incl. ephemeral / serverless via cloud connectors
Inventory refresh (Control 1.1)	Monthly	Weekly	Continuous (real-time alert on net-new)
Software inventory (Control 2.1)	Monthly	Bi-weekly	Continuous + signed allow-list (2.6)
Config baseline (Control 4.1)	Documented	Documented + automated drift	Drift attribution to change ticket

Aspect	IG1 baseline	IG2 baseline (default)	IG3 add
		detection	
Vulnerability scan cadence (Control 7.5)	Monthly	Weekly	Continuous, with reachability context
Log retention (Control 8.10)	90 days	90 days + central SIEM	Per regulatory obligation; common is 1 year+
Segmentation (Control 12.4)	Macrosegmentation	Macro + microsegmentation for sensitive scopes	Microsegmentation everywhere; deny-by-default default
Network monitoring (Control 13.1)	Border / SIEM	Border + east-west sampling	East-west everywhere with behavioural detection

CSW Implementation: apply IG-aligned labels at workload onboarding:

```
Step 1: Apply CIS context labels
  CSW UI → Inventory → Bulk Label
  Mandatory labels:
    cis_ig:           ig1 | ig2 | ig3
    asset_class:      server | workstation | container | cloud-vm |
serverless
    data_sensitivity: public | internal | confidential | regulated
    business_unit:    [BU identifier]
    environment:      production | staging | dev

Step 2: Build CSW Scopes per (cis_ig, environment, data_sensitivity)
  CSW UI → Organize → Scopes → New
  → IG2 scopes inherit IG1 expectations and add IG2 Safeguards

Step 3: Configure cadence policies per IG tier
  → CSW reports (Inventory, Software, Vulnerability) scheduled to
    the cadence row above for the relevant IG
```

---

3. Scope Architecture and Labeling

Section 2 establishes *which* Safeguards are in force for your IG. This section turns that into a structure CSW can enforce and export against. The scope tree is the shared substrate for Controls 1 and 2 (you cannot inventory what is not in a scope), Control 12 (segmentation is expressed between scopes) and Control 13 (monitoring is scoped traffic filtering).

3.1 Suggested Scope Architecture

```
Root Scope
└── Enterprise-Assets
    ├── Sensitive-Data-Assets            (data_sensitivity =
regulated | confidential)
    │   ├── Regulated-Data-Stores
    │   └── Regulated-Data-Processing
    ├── Production-Servers
    ├── Network-Infrastructure-Mgmt      (infrastructure admin plane
— Control 12)
    ├── Security-Services                (EDR, SIEM, scanners —
Control 13)
    ├── Admin-Workstations               (dedicated administrative
plane — Safeguard 12.8)
    └── Out-of-Scope-Corporate
```

Keeping `Admin-Workstations` as a peer branch rather than a child of `Production-Servers` is deliberate: Safeguard 12.8 asks for dedicated computing resources for administrative work, and a scope tree that nests the admin plane inside the thing it administers cannot evidence that.

3.2 Inventory Filters

```
Filter: Regulated-Data-Stores
  - Tag: data_sensitivity = regulated
  - Listening port: 1433, 1521, 3306, 5432, 27017

Filter: Unmanaged-Asset-Candidates
  - Present in flow telemetry but absent from CSW Inventory
  - No agent and no cloud-connector record

Filter: Admin-Workstations
  - Tag: asset_class = workstation
  - Observed outbound to tcp/22, tcp/3389, tcp/5985 on Production-
Servers

Filter: Unauthorized-Software-Candidates
  - Process observed on a workload but absent from the approved
software list
  - Tag: environment = production
```

`Unmanaged-Asset-Candidates` is the filter that does the most work for Control 1. Safeguard 1.1 asks for an accurate asset inventory; the hard part is never the assets you know about, it is detecting the ones that appear only as the far end of an observed flow.

3.3 Labeling Strategy

The five mandatory keys from section 2 carry the IG calibration; the remaining keys below make Controls 1, 2 and 12 queryable. Apply all of them at onboarding rather than retrofitting before an assessment.

Label key	Example values	Why it matters for CIS v8
`cis_ig`	ig1, ig2, ig3	*(section 2)* Sets which Safeguards are in force and the evidence cadence
`asset_class`	server, workstation, container, cloud-vm, serverless	*(section 2)* Control 1 enterprise-asset classification
`data_sensitivity`	public, internal, confidential, regulated	*(section 2)* Drives Safeguard 3.12 data segmentation and scope membership
`business_unit`		*(section 2)* Ownership for Safeguard 1.1 inventory attestation
`environment`	production, staging, dev	*(section 2)* Environment separation evidence
`software_baseline`		Control 2 — the approved software list this asset is measured against
`config_baseline`		Control 4 — the secure configuration this asset is measured against
`admin_plane`	true, false	Safeguard 12.8 — marks the dedicated administrative resources
`compliance`	cis-v8	Filters CSW evidence to the CIS assessment boundary

4. Policy Design — Deny-by-Default Allowlist

Control 12 asks for a secure network architecture and Control 13 for traffic filtering between segments. Both are satisfied by the same artifact: a workload allowlist with a deny-by-default posture, enforced and exportable. Calibrate the breadth against the segmentation row of the section 2 IG table — IG1 expects macrosegmentation, IG2 adds microsegmentation for sensitive scopes, IG3 expects it everywhere.

4.1 CIS-Aligned Policy Framework

Absolute policies:

```
DENY  Any                          → Sensitive-Data-Assets
(default deny inbound — Safeguard 4.4)
DENY  Sensitive-Data-Assets        → Internet                      (no
direct egress from regulated data)
DENY  Out-of-Scope-Corporate       → Sensitive-Data-Assets
(admin only via the dedicated plane)
DENY  Production-Servers           → Admin-Workstations
(admin plane is not a destination — 12.8)
```

Allowlist policies (least privilege):

```
ALLOW Regulated-Data-Processing    → Regulated-Data-Stores
tcp/<db-port-tls>
ALLOW Production-Servers           → Security-Services
tcp/443
ALLOW Admin-Workstations           → Production-Servers
tcp/22, tcp/3389
ALLOW Admin-Workstations           → Network-Infrastructure-Mgmt
tcp/22, tcp/443
ALLOW Enterprise-Assets            → Security-Services
udp/514
```

Catch-all:

```
LOG   Any                          → Sensitive-Data-Assets
(unmatched inbound — Safeguard 13.4)
LOG   Sensitive-Data-Assets        → Any
(unmatched outbound)
LOG   Enterprise-Assets            → Any
(plaintext: tcp/80, tcp/21, tcp/23, tcp/389, udp/161)
```

4.2 Policy Workspace Lifecycle

Phase	Mode	Duration	Purpose
1	Simulation	2 weeks	Validate the candidate policy
2	Enforcement (high-confidence rules only)	1 week	Enforce obvious deny rules
3	Full Enforcement	Ongoing	Workload allowlist enforced; monthly exception review

Workspace snapshots are Control 12 architecture evidence and the Denied Connections log is Control 13 filtering evidence. The simulation report is what lets you show an assessor that the policy was reviewed before it was enforced, which is the part most programmes cannot produce.

---

5. Control 1 — Inventory and Control of Enterprise Assets

IG2 Safeguards in scope: 1.1 (inventory), 1.2 (address unauthorised assets), 1.3 (utilise active discovery), 1.4 (DHCP logging — not CSW), 1.5 (passive discovery).

CSW Implementation:

```
Step 1: Achieve sensor coverage (Safeguard 1.1)
  → Linux:   yum/dnf/apt + systemctl enable csw-agent
  → Windows: MSI install + service verification
  → Containers: DaemonSet sensor for K8s; per-node sensor for
ECS/AKS/GKE
  → Cloud:   External Orchestrators (AWS/Azure/GCP) for asset metadata

Step 2: Configure cloud connectors for agentless inventory
  CSW UI → Platform → External Orchestrators
  → AWS account / Azure subscription / GCP project
  → CSW polls API for instance inventory regardless of agent state
  → Captures Safeguard 1.5 passive discovery for ephemeral workloads

Step 3: Reconcile against your authoritative source (CMDB)
  → Schedule weekly export from CSW inventory API
  → Diff against CMDB; investigate any delta
  → IG3: real-time alert on net-new workload not in CMDB

Step 4: Quarantine unauthorised workloads (Safeguard 1.2)
  → Pre-built CSW policy: deny-all except management plane
  → Apply to any workload tagged unauthorised=true
  → IG2 expectation: investigate and quarantine within 1 week;
    IG3 expectation: within 24 hours
```

Evidence: (a) inventory snapshot per IG cadence; (b) reconciliation diff log against CMDB; (c) unauthorised-asset quarantine log.

IG1 delta: monthly inventory snapshot + manual diff is acceptable. **IG3 delta:** continuous inventory with real-time net-new alerting and sub-24-hour quarantine.

---

6. Control 2 — Inventory and Control of Software Assets

IG2 Safeguards in scope: 2.1 (software inventory), 2.2 (ensure authorised software supported), 2.3 (address unauthorised software), 2.5 (allow-list), 2.6 (allow-list libraries).

CSW Implementation:

```
Step 1: Continuous software inventory (Safeguard 2.1)
  CSW UI → Investigate → Inventory → Workload → Software & Packages
  → Auto-captured: package name, version, install date, source
  → Per-workload export available via API; aggregated by scope
```

```
Step 2: Detect unsupported software (Safeguard 2.2)
  → Cross-reference inventory against your supported-software list
  → Flag workloads running software past vendor support EOL
  → Route to platform team for upgrade or risk acceptance

Step 3: Detect unauthorised software (Safeguard 2.3)
  → Define allow-list per asset_class (server, workstation, container)
  → CSW alert: software outside the allow-list observed
  → IG2 expectation: investigate within 1 week
  → IG3 expectation: prevent execution via behavioural policy + alert

Step 4: Allow-list enforcement (Safeguards 2.5, 2.6)
  → IG2: allow-list documented; CSW alerts on deviation
  → IG3: allow-list enforced via behavioural policy (block on
    unknown binary execution); CSW process telemetry feeds the
    enforcement decision
```

Evidence: (a) per-workload software inventory dated to cadence; (b) unsupported-software register; (c) unauthorised-software alert log with disposition.

IG1 delta: monthly inventory; manual review of unauthorised software is sufficient. **IG3 delta:** allow-list enforcement (block, not just alert) on unknown binary execution.

---

7. Control 4 — Secure Configuration of Enterprise Assets and Software

IG2 Safeguards in scope: 4.1 (process for configuration), 4.2 (secure configuration of network infra), 4.4 (default deny via firewall — see Control 13), 4.5 (automatically manage default accounts — IG3), 4.6 (secure configuration of software).

CSW Implementation:

```
Step 1: Capture configuration baseline per workload (Safeguard 4.1)
  → CSW continuously inventories: OS + kernel, package list, listening
    ports, running processes, key file presence
  → Snapshot daily to CSW data tap; this is the IG2 baseline of record

Step 2: Drift detection (Safeguard 4.1)
  → Daily diff between today's snapshot and yesterday's
  → Per-workload report: what changed in packages, ports, processes
  → IG2 expectation: review weekly; investigate unexplained drift
  → IG3 expectation: drift attribution to a change ticket within 24h

Step 3: Hardening enforcement via CSW segmentation policy (4.4, 4.6)
  → Default deny inbound to every workload except documented services
  → Plaintext-protocol DENY (HTTP, FTP, Telnet, LDAP plaintext)
  → Limit outbound to documented destinations per asset_class

Step 4: Tie drift to change-management (Safeguard 4.1)
  → Correlate CSW-observed change timestamp against change-ticket
```

```
    timestamp
  → Orphan changes (CSW-detected, ticket-absent) = unauthorised
    change candidates; route to incident process
```

Evidence: (a) baseline export per workload; (b) daily drift log with disposition; (c) segmentation policy export per scope.

IG1 delta: documented baseline; manual quarterly review. **IG3 delta:** automated drift attribution; default-account management automation tied to inventory.

---

8. Control 7 — Continuous Vulnerability Management

IG2 Safeguards in scope: 7.1 (process for vulnerability management), 7.2 (process for remediation), 7.3 (automated patch mgmt of OS), 7.4 (automated patch mgmt of apps), 7.5 (perform automated vulnerability scans of internal assets), 7.6 (perform automated vulnerability scans of externally-exposed assets), 7.7 (remediate detected vulnerabilities).

CSW Implementation:

```
Step 1: Continuous CVE inventory at workload level (Safeguard 7.5)
  CSW UI → Investigate → Vulnerability Report
  → Per-workload CVE list with CVSS, EPSS, exploit availability
  → Updated continuously as the CSW CVE database refreshes
  → IG2 cadence: weekly export to remediation queue
  → IG3 cadence: continuous, real-time prioritisation

Step 2: Reachability-aware prioritisation (Safeguard 7.7)
  → CSW maps each CVE to the workload's actual ingress/egress
    paths in the conversation graph
  → Vulnerable port + actually reachable from internet = top priority
  → Vulnerable port + no observed flow + no reachable path = lower
    priority (validate compensating control before deferral)

Step 3: Track patch SLA per asset_class and CVSS band
  → Critical (9+) on internet-reachable: patch within 48 hours
  → High (7-8.9) on internal: patch within 30 days
  → Medium (4-6.9): patch within 60 days
  → Trend report monthly to security leadership

Step 4: Compensating controls when patching is delayed
  → Restrict source set for the vulnerable port via CSW policy
  → Add behavioural detection for known exploit patterns
  → Document the compensating control in workspace notes
  → This is the audit trail for "remediation" when patch is deferred
```

Evidence: (a) per-workload CVE list dated to IG cadence; (b) patch SLA compliance trend; (c) compensating-control register for deferred patches.

IG1 delta: monthly scan; manual prioritisation acceptable. **IG3 delta:** continuous scanning, automated reachability scoring, sub-week patch SLA on critical exposed assets.

---

9. Control 8 — Audit Log Management

IG2 Safeguards in scope: 8.1 (log management process), 8.2 (collect audit logs), 8.5 (collect detailed audit logs), 8.7 (retain audit logs), 8.10 (retain audit logs for 90 days minimum), 8.11 (conduct audit log reviews).

CSW Implementation:

```
Step 1: Configure SIEM forwarding (Safeguard 8.2)
  CSW UI → Manage → Data Tap → SIEM
  → Splunk HEC, QRadar, Sentinel, Cisco XDR, syslog
  → Forward: workload flow records, process events, policy violations,
    behavioural detections, vulnerability events

Step 2: Confirm IG2-grade logging detail (Safeguard 8.5)
  → Per-flow: source, destination, port, byte counts, timestamps,
    process attribution, scope context
  → Per-process: command line, parent-child, file accesses, network
    activity
  → Per-event: detection rule fired, severity, evidence

Step 3: Retention (Safeguards 8.7, 8.10)
  → IG2 minimum: 90 days at the SIEM
  → For regulated data: extend per applicable framework (HIPAA: 6 yr;
    PCI: 1 yr active + 1 yr archive; etc.)

Step 4: Audit log reviews (Safeguard 8.11)
  → IG2: weekly review of CSW alert summary; quarterly trend review
  → IG3: SOC reviews real-time; CSW alerts feed playbook automation
```

Evidence: (a) SIEM forwarding configuration screenshot; (b) log retention policy and compliance evidence; (c) sample log review minutes per cadence.

IG1 delta: logs to local file with weekly review; SIEM forwarding optional. **IG3 delta:** real-time SOC review with playbook automation; extended retention per compliance overlay.

---

10. Control 12 — Network Infrastructure Management

IG2 Safeguards in scope: 12.1 (network infrastructure maintained), 12.2 (use secure protocols), 12.4 (establish & maintain architecture diagrams), 12.5 (centralise network AAA).

CSW does not configure routers or switches. It contributes by making the **workload-side** enforcement layer visible and documented, which feeds Safeguards 12.4 (architecture diagrams) and 12.2 (secure protocols).

CSW Implementation:

```
Step 1: Generate the workload-side architecture diagram (12.4)
  CSW UI → Investigate → Application Dependency Mapping → Workspace
  → ADM clusters become the as-observed application architecture
  → Export the dependency graph; pair with your network team's
    diagram for a complete view

Step 2: Detect insecure protocols in flight (12.2)
  → CSW reports: any plaintext flow (HTTP, FTP, Telnet, LDAP, SMTP)
  → Alert on insecure flows from sensitive scopes
  → Block via segmentation policy as remediation
```

Evidence: (a) ADM dependency export; (b) plaintext-flow alert log.

---

11. Control 13 — Network Monitoring and Defense

IG2 Safeguards in scope: 13.1 (centralised monitoring), 13.2 (deploy host-based intrusion detection — see also Control 10), 13.3 (network intrusion detection), 13.4 (perform traffic filtering between network segments), 13.5 (manage access control for remote assets), 13.6 (collect network traffic flow logs), 13.7 (deploy host-based intrusion prevention — IG3), 13.8 (deploy network intrusion prevention — IG3), 13.9 (deploy port-level access control — IG3), 13.10 (perform application-layer filtering — IG3).

This is the densest CSW alignment in the entire CIS Controls. CSW runs at the workload, observes every flow, applies behavioural analytics, enforces segmentation, and forwards to the SIEM.

CSW Implementation:

```
Step 1: Centralised monitoring (Safeguard 13.1, 13.6)
  → CSW collects every flow on every CSW-managed workload
  → Forwarded to SIEM continuously; retained at CSW for the data
    retention window (typically 30 days; configurable)

Step 2: East-west traffic filtering (Safeguard 13.4)
  → Build segmentation policy per scope; deny-by-default
  → Run in Simulation 30+ days; resolve legitimate-but-blocked flows
  → Promote to Enforce; quarterly diff report

Step 3: Behavioural detection (Safeguards 13.2, 13.3)
  → Out-of-the-box rules: privilege escalation, persistence, lateral
    movement, suspicious child processes
  → Custom rules: encode org-specific abuse patterns
  → IG3: tie to playbook automation for sub-15-minute MTTR

Step 4: Anomaly detection (Safeguards 13.3, 13.8)
  → Conversation graph: flag new edges in workload-to-workload
    communication
```

```
  → Port/protocol distribution anomalies per workload

Step 5: Remote-asset access control (Safeguard 13.5)
  → Identify remote-management paths in CSW (VPN concentrators,
    bastion hosts, admin VPN ranges)
  → Limit allow rules for management protocols (22, 3389, WinRM) to
    those source sets only
```

Evidence: (a) segmentation policy export with simulation→ enforcement log; (b) detection rule catalogue; (c) anomaly alert log; (d) flow telemetry retention configuration.

IG1 delta: flow logs at the border; simple deny rules; weekly review of suspicious activity. **IG3 delta:** Safeguards 13.7–13.10 layered (HIPS, NIPS, port-level access, app-layer filtering); CSW behavioural rules feed automated response.

---

12. Control 17 — Incident Response Management

IG2 Safeguards in scope: 17.1 (designate IR personnel), 17.2 (establish & maintain contact information), 17.3 (establish & maintain IR process), 17.4 (test IR process), 17.5 (assign roles), 17.6 (define mechanisms for reporting), 17.8 (track post-incident review).

CSW is not the IR playbook owner. CSW supplies the **evidence substrate** that lets each step of the IR process produce defensible artefacts.

CSW Implementation — Six-Artefact IR Bundle:

```
For each declared incident on a CSW-managed workload:

  (a) Affected workload set
      → Inventory query: hostnames, IPs, OS, scope labels, owner

  (b) Time-anchored flow record
      → CSW historical conversations: source, destination, port, byte
        counts, timestamps, process attribution

  (c) Process activity record
      → Every process spawned on affected workloads in the window

  (d) Software footprint at time of incident
      → Package list, CVE exposure at that moment (not "today")

  (e) Containment evidence
      → Quarantine policy applied; flow drop count after policy;
        time-to-quarantine

  (f) Post-incident control proof
      → Diff between pre-incident segmentation and remediated state
```

Evidence: (a) incident dossier per declared event; (b) MTTD/MTTR trend per quarter; (c) post-incident review (Safeguard 17.8) inputs.

---

13. Control 18 — Penetration Testing (Supporting)

IG2 Safeguards in scope: 18.1 (establish & maintain pen test program), 18.2 (perform periodic external pen tests), 18.3 (remediate pen test findings), 18.5 (perform periodic internal pen tests).

CSW Implementation:

```
Step 1: Pre-test reachability baseline (Safeguard 18.5)
  → CSW "what-if" reachability query for the test scope
  → Output: who can reach what, on which port, with which identity
  → Hand to the red team as the engagement scoping document

Step 2: During test
  → Defenders may observe in "purple" mode
  → CSW alerts can be observed but not acted on without abort

Step 3: Post-test reachability comparison
  → Re-run reachability query; diff vs. pre-test
  → Document: which segmentation rules held, which were bypassed,
    which detections fired vs. missed (Safeguard 18.3 input)
```

Evidence: (a) pre-test reachability report; (b) red-team activity reconstruction; (c) post-test gap analysis.

---

14. Mapping Table — CIS Controls v8.1 → CSW Capability

Safeguard	Title	CSW capability
1.1	Inventory of enterprise assets	Continuous workload inventory + cloud asset metadata
1.2	Address unauthorised assets	Quarantine policy applied to net-new workloads
1.3	Active discovery	Sensor coverage + cloud connectors
1.5	Passive discovery	Cloud orchestrator polling for ephemeral assets
2.1	Software inventory	Per-workload package + version inventory
2.2	Authorised software	Cross-reference against

Safeguard	Title	CSW capability
	supported	vendor-support list
2.3	Address unauthorised software	Alert + (IG3) behavioural-policy block
2.5–2.6	Allow-listed software / libraries	Allow-list catalogue + behavioural enforcement
4.1	Secure configuration process	Daily baseline + drift report tied to change ticket
4.2	Network infra config	Workload-side complement to network-team config
4.4	Default-deny on FW	CSW segmentation enforcement at the workload
4.6	Secure software config	Per-workload listening-port + service inventory
6.1–6.5	Access control management	Workload-side enforcement; identity is upstream
7.1–7.7	Continuous vulnerability mgmt	Continuous CVE inventory + reachability prioritisation
8.2	Collect audit logs	SIEM forwarding configuration
8.5	Detailed audit logs	Per-flow + per-process + per-event detail
8.7, 8.10	Retain audit logs	SIEM retention policy + CSW window
8.11	Audit log reviews	Quarterly review of CSW alert summary
10.1–10.7	Malware defenses	Behavioural rules layered with endpoint AV
12.2	Secure protocols	Plaintext-flow detection + DENY enforcement
12.4	Architecture diagrams	ADM dependency export
13.1, 13.6	Centralised monitoring + flow logs	CSW flow telemetry + SIEM forwarding
13.2, 13.3	Host + network IDS	Behavioural rules + anomaly detection

Safeguard	Title	CSW capability
13.4	Traffic filtering between segments	CSW segmentation policy enforcement
13.5	Remote-asset access control	Restrict mgmt protocol allow rules to bastion sources
13.7–13.10	HIPS, NIPS, port-level, app-layer filtering	Behavioural rules + segmentation enforcement
15.1, 15.4	Service provider mgmt (technical lens)	Vendor-egress observation + reconciliation
16.1, 16.6	Application sec process / vuln mgmt	CVE inventory feeds SDLC + reachability for triage
17.1–17.8	Incident response process	Six-artefact incident dossier (§12)
18.1–18.5	Penetration testing	Pre/post reachability + activity reconstruction

15. Auditor / Assessor Response Guide

When a CIS Controls assessment asks for evidence:

Assessor asks	You provide
"Show me your IG2 IT asset inventory dated last month"	CSW inventory snapshot CSV per scope
"Demonstrate Safeguard 4.1 configuration management"	Daily baseline + drift report with change-ticket attribution
"Provide Safeguard 7.5 vulnerability scan evidence"	Weekly CVE export per workload, dated within the period
"Show Safeguard 8.10 90-day log retention"	SIEM retention policy + sample retrieval over the window
"Demonstrate Safeguard 13.4 segmentation between segments"	CSW workspace export + simulation → enforcement log
"Provide Safeguard 13.6 flow logs for incident X"	Per-flow export with timestamps + process attribution
"Show Control 17 incident dossier"	Six-artefact bundle (§12)
"Show Safeguard 18.5 internal pen test evidence"	Pre/post reachability + red-team activity reconstruction

16. Related Frameworks

CIS Controls v8.1 maps cleanly to:

- **NIST SP 800-53 Rev 5** — CIS publishes an official 800-53 mapping; many CIS Safeguards correspond to specific 800-53 controls. See 800-53 reference design.
- **NIST CSF 2.0** — CIS Safeguards are commonly cited as Informative References under CSF subcategories. See CSF reference design.
- **CMMC 2.0 (Level 2)** — both inherit heavily from NIST 800-171 / 800-53. See CMMC reference design.
- **PCI DSS v4.0** — many Reqs (1, 2, 7, 10, 11) align directly with CIS Controls 4, 6, 8, 13. See PCI reference design.
- **ISO/IEC 27001:2022** — Annex A controls have substantial overlap with CIS Safeguards. See ISO 27001 reference design.
- **UK NCSC CAF v3.2** — Controls 1, 2, 4, 7, and 13 are the reuse path for CAF A3, B4, B5, and C1 (see CAF crosswalk).

---

17. Disclaimer

This reference design is **draft v1** describing how Cisco Secure Workload capabilities can support a CIS Critical Security Controls v8.1 programme. It is **not** legal or compliance advice and does not constitute a finding of compliance.

Specifically:

- CIS publishes the authoritative Safeguard text and IG mapping at https://www.cisecurity.org/. Always validate against the **current effective version** of the Controls.
- Mapping a Safeguard to a CSW capability does not by itself satisfy the Safeguard. Safeguards expect documented process, evidence cadence, and management review — CSW supplies the technical layer that those process requirements depend on.
- CSW does not address Controls 5, 9, 11, 14 in any meaningful way; reference your identity, email/web, backup, and training stacks for those.

This document should receive subject-matter-expert review for both CIS Controls accuracy and current Cisco product capability before being relied upon in a formal compliance engagement.